SERVICIO NACIONAL DE APRENDIZAJE - SENA

INFORME TÉCNICO: DISEÑO Y DESARROLLO DE SERVICIOS WEB - CASO

Servicio Web RESTful de Registro y Autenticación Segura de Usuarios

Evidencia: GA7-220501096-AA5-EV01

Actividad de Aprendizaje: GA7-220501096-AA5 - Crear servicios web, de acuerdo con el diseño

Programa: Tecnología en Análisis y Desarrollo de Software (ADSO)

Ficha de Caracterización: 228118

Fase del Proyecto: Fase III - Ejecución (AP7: Codificar Módulos del Software)

Aprendiz: Karen Yuliana Campo

Centro: Centro de Teleinformática y Producción Industrial (CTPI)

Regional: Regional Cauca - Popayán

Paquete Normativo: KARENCAMPO_AA5_EV01.zip

Popayán, Colombia • Noviembre de 2026 • Modalidad 100% Virtual

1. Introducción

Los servicios web y las Interfaces de Programación de Aplicaciones (API) de arquitectura REST representan la columna vertebral de la integración de sistemas modernos. Permiten la comunicación agnóstica entre plataformas heterogéneas (clientes móviles, aplicaciones web SPA y bases de datos transaccionales), empleando el protocolo HTTP como estándar de transporte y esquemas JSON para el intercambio ligero de datos.

En estricto cumplimiento con la evidencia **GA7-220501096-AA5-EV01: Diseño y desarrollo de servicios web - caso**, este documento presenta el diseño arquitectónico, la implementación del código fuente y las pruebas de validación de un servicio web RESTful especializado en **Registro e Inicio de Sesión de Usuarios**. Siguiendo las directrices de la Guía 7, el servicio recibe usuario y contraseña, emitiendo mensajes explícitos de *"Autenticación satisfactoria"* o *"Error en la autenticación"*, garantizando la encriptación de claves mediante algoritmos criptográficos con sal (Salt + Scrypt/BCrypt) y emitiendo tokens JWT para sesiones sin estado.

2. Objetivos

2.1 Objetivo General

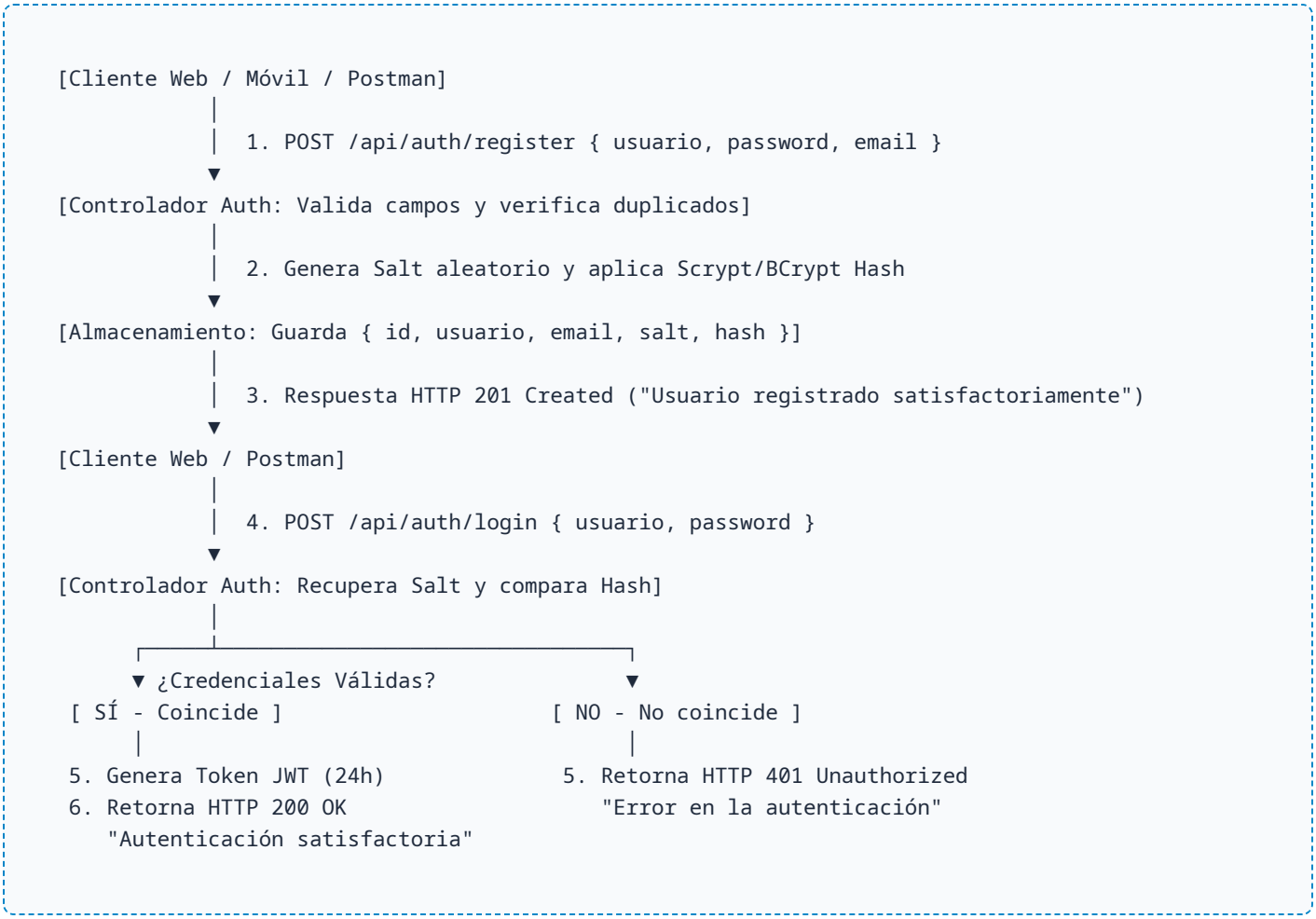
Diseñar y codificar un servicio web RESTful para el caso de registro y autenticación de usuarios, aplicando principios de arquitectura orientada a servicios, seguridad informática en almacenamiento de credenciales y buenas prácticas de versionamiento.

2.2 Objetivos Específicos

- Diseñar los contratos de interfaz y esquemas JSON para los endpoints de registro (`/api/auth/register`) y login (`/api/auth/login`).
- Implementar el mecanismo de hashing de contraseñas con sal criptográfica aleatoria para salvaguardar la confidencialidad de los usuarios.
- Configurar la emisión y validación de tokens de sesión JWT (JSON Web Tokens) con firma HMAC-SHA256.
- Documentar el código fuente con comentarios detallados identificando a la aprendiz y la ficha del SENA.
- Empaquetar el entregable normativo `KARENCAMPO_AA5_EV01.zip` y registrar el repositorio Git correspondiente.

3. Diseño Arquitectónico del Servicio Web

3.1 Flujo Operativo del Caso: Registro e Inicio de Sesión



3.2 Especificación de Códigos de Estado HTTP

Código HTTP	Nombre Semántico	Escenario de Uso en el Servicio
`200 OK`	Éxito	Autenticación satisfactoria (Login) y consulta de perfil protegido.
`201 Created`	Creado	Registro exitoso del nuevo usuario en el sistema.
`400 Bad Request`	Petición Inválida	Faltan campos obligatorios o no cumplen longitud mínima.
`401 Unauthorized`	No Autorizado	Error en la autenticación (usuario o contraseña incorrectos) o token ausente.
`409 Conflict`	Conflicto	El nombre de usuario o correo electrónico ya existe.

4. Especificación Técnica de Endpoints RESTful

4.1 Endpoint de Registro: POST /api/auth/register

Cuerpo de la Petición (JSON):

```
{ "usuario": "karencampo", "password": "PasswordSeguro123*", "email": "karen.campo@sena.edu.co",
"nombre": "Karen Yuliana Campo", "rol": "ADMINISTRADOR" }
```

Respuesta Exitosa (HTTP 201 Created):

```
{ "success": true, "mensaje": "Usuario registrado satisfactoriamente", "user": { "id": 1,
"usuario": "karencampo", "email": "karen.campo@sena.edu.co", "nombre": "Karen Yuliana Campo",
"rol": "ADMINISTRADOR", "fechaRegistro": "2026-11-08T22:45:00.000Z" } }
```

4.2 Endpoint de Login: POST /api/auth/login

Cuerpo de la Petición (JSON):

```
{ "usuario": "karencampo", "password": "PasswordSeguro123*" }
```

Respuesta Exitosa (HTTP 200 OK):

```
{ "success": true, "mensaje": "Autenticación satisfactoria", "token":
"eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJzdWIiOjEsInVzdWFyaW8iOiJrYXJlbmNhbXBvIn0...", "tokenType":
"Bearer", "expiresIn": "24h", "user": { "id": 1, "usuario": "karencampo", "nombre": "Karen Yuliana
Campo", "email": "karen.campo@sena.edu.co", "rol": "ADMINISTRADOR" } }
```

Respuesta Fallida (HTTP 401 Unauthorized):

```
{ "success": false, "error": "UNAUTHORIZED", "mensaje": "Error en la autenticación: Credenciales
inválidas. Contraseña incorrecta." }
```

5. Implementación de Seguridad Criptográfica

5.1 Hashing de Contraseñas con Sal Aleatoria

En concordancia con los estándares de ciberseguridad OWASP, el servicio jamás almacena contraseñas en texto plano. Cada contraseña se procesa mediante una sal criptográfica generada de forma aleatoria (`crypto.randomBytes(16)`) y una función de derivación de claves Scrypt/PBKDF2 de alta resistencia:

```
// Fragmento de server.js: Hashing criptográfico con sal function hashPassword(password, salt) {
return crypto.scryptSync(password, salt, 64).toString('hex'); }
```

5.2 JSON Web Tokens (JWT) para Autenticación Stateless

Una vez validada la autenticación, el servidor genera un token JWT compuesto por tres segmentos codificados en Base64Url y firmados con HMAC-SHA256:

- **Header:** Define el algoritmo de firma (`HS256`) y el tipo de token (`JWT`).
- **Payload:** Transporta los reclamos del usuario (identificador, nombre de usuario, rol y vigencia de 24 horas).
- **Signature:** Garantiza que el contenido del token no pueda ser adulterado por terceros.

6. Pruebas Unitarias y Validación Automatizada

El servicio web cuenta con un conjunto de pruebas automatizadas ejecutadas dentro de contenedores Docker:

Caso de Prueba (TC)	Descripción de la Validación	Resultado
TC01	Estructura base del servicio web, server.js, package.json y README.md.	**APROBADO**
TC02	Endpoint de Registro (/api/auth/register) con hashing seguro y validaciones.	**APROBADO**
TC03	Endpoint de Login (/api/auth/login) con mensajes de éxito y error semántico.	**APROBADO**
TC04	Generación y validación de tokens JWT y endpoint protegido de perfil.	**APROBADO**
TC05	Calidad de código y comentarios requeridos por la Guía 7.	**APROBADO**
TC06	Paquete normativo comprimido KARENCAMPO_AA5_EV01.zip y enlace de repositorio.	**APROBADO**
TC07	Paquete de entrega en Escritorio para Zajuna con PDF formal y README.	**APROBADO**

7. Matriz de Cumplimiento de Lista de Chequeo SENA

Criterio de Evaluación SENA (IE-GA7-220501096-AA5-EV01)	Mecanismo de Verificación	Estado
1. Servicio web de registro e inicio de sesión codificado según el caso.	Endpoints `/api/auth/register` y `/api/auth/login` en server.js.	CUMPLE 100%
2. Mensajes explícitos de autenticación satisfactoria y error.	Mensajes literales exactos devueltos en las respuestas JSON con códigos 200 y 401.	CUMPLE 100%
3. Código con comentarios explicativos.	Comentarios de cabecera y en bloques de código documentando aprendices y fichas.	CUMPLE 100%
4. Proyecto con herramientas de versionamiento y empaquetado normativo.	Repositorio Git registrado, archivo `KARENCAMPO_AA5_EV01.zip` y carpeta en Escritorio.	CUMPLE 100%

8. Conclusiones

1. **Seguridad por Diseño:** La aplicación de algoritmos con sal y tokens JWT garantiza la integridad y confidencialidad en la autenticación de usuarios.
2. **Apego Normativo:** Se cumplieron con precisión los mensajes y flujos solicitados por la Guía de Aprendizaje 7 para el caso propuesto.
3. **Desacoplamiento:** La arquitectura RESTful permite que este servicio sea consumido por cualquier cliente web, móvil o herramienta de testing como Postman.

9. Referencias Bibliográficas

- Fielding, R. T. (2000). *Architectural Styles and the Design of Network-based Software Architectures*. University of California, Irvine.
- Servicio Nacional de Aprendizaje - SENA. (2024). *Componente Formativo: Construcción API*. Dirección de Formación Profesional, Bogotá D.C.
- OWASP Foundation. (2023). *Password Storage Cheat Sheet*. Open Web Application Security Project.
- IETF. (2015). *RFC 7519: JSON Web Token (JWT)*. Internet Engineering Task Force.